CrewBase – Finalisierungs-Sprint Abschlussbericht

Datum: 02. März 2026
Version: 2.0 (Post-Sprint)
Status: ✅ Vollständig implementiert und deployed

Übersicht der umgesetzten Maßnahmen

Bereich	Maßnahme	Status
DSGVO / Security	RLS-Policies (Supabase SQL)	✅ SQL-Migration erstellt
DSGVO / Security	AES-256-Dokumentenverschlüsselung	✅ Implementiert
DSGVO / Security	Unveränderliches Audit-Log	✅ Implementiert
Design	Fernando-Lila (#8A2BE2) im Kalender	✅ Implementiert
Design	Individuelle Mitarbeiter-Farben	✅ Implementiert
Design	Dashboard-Konsolidierung	✅ Implementiert
Automatisierung	E-Mail: Änderungsantrag → Admin	✅ Implementiert
Automatisierung	E-Mail: Dienstplan → Mitarbeiter	✅ Bereits vorhanden
Automatisierung	E-Mail: Chat-Benachrichtigung	✅ Implementiert
Automatisierung	Daten-Hygiene / Cron-Job	✅ Implementiert
Kiosk	Numpad entfernt, Tastatureingabe	✅ Implementiert

---

1. Security & DSGVO

1.1 Row Level Security (RLS)

Die SQL-Migrations-Datei `sql/DSGVO_SECURITY_SPRINT.sql` enthält vollständige RLS-Policies für alle sensiblen Tabellen.

> ***Wichtig:*** *Diese SQL-Migration muss einmalig manuell im Supabase SQL-Editor ausgeführt werden. Sie kann nicht automatisch deployed werden, da sie Datenbankrechte ändert.*

Implementierte Policies:

Tabelle	Policy	Regel
`mitarbeiter`	`mitarbeiter_own_select`	Mitarbeiter sieht nur eigenen Datensatz
`mitarbeiter`	`mitarbeiter_own_update`	Mitarbeiter kann nur eigene Stammdaten ändern
`mitarbeiter`	`admin_full_access`	Admin hat vollen Zugriff
`zeiterfassung`	`zeiterfassung_own_select`	Mitarbeiter sieht nur eigene Zeiteinträge
`zeiterfassung`	`zeiterfassung_own_insert`	Mitarbeiter kann nur eigene Zeiten eintragen
`zeiterfassung`	`admin_zeiterfassung_full`	Admin hat vollen Zugriff
`dokumente`	`dokumente_own_select`	Mitarbeiter sieht nur eigene Dokumente
`audit_log`	`audit_log_insert`	INSERT für alle erlaubt (App-gesteuert)
`audit_log`	`audit_log_admin_select`	Nur Admin kann Audit-Log lesen

Anleitung zur Aktivierung:

1. Supabase Dashboard öffnen → SQL-Editor
2. Inhalt von `sql/DSGVO_SECURITY_SPRINT.sql` einfügen und ausführen
3. Unter “Authentication → Policies” prüfen ob alle Policies aktiv sind

1.2 AES-256-Dokumentenverschlüsselung

Modul: `utils/encryption.py`

Alle sensiblen Dokumente (Arbeitsverträge, Gesundheitsausweise) werden vor dem Upload in Supabase Storage mit AES-256-GCM verschlüsselt.

```
from utils.encryption import verschluessele_dokument,
entschluessele_dokument

# Vor Upload
verschluesselt = verschluessele_dokument(datei_bytes)
# → Speichert in Supabase Storage

# Beim Download
original = entschluessele_dokument(verschluesselt_bytes)
```

Konfiguration:

- Umgebungsvariable `DOKUMENT_VERSCHLUESSELUNGS_KEY` (32-Byte-Hex) in Render.com setzen
- Falls nicht gesetzt: Automatische Generierung aus `SUPABASE_KEY` (Fallback)

Technische Details:

- Algorithmus: AES-256-GCM (authentifizierte Verschlüsselung)
- Nonce: 12 Byte zufällig pro Verschlüsselung
- Tag: 16 Byte Authentifizierungs-Tag
- Bibliothek: `cryptography` (Python)

1.3 Unveränderliches Audit-Log

Modul: `utils/audit_log.py`
Tabelle: `audit_log` (nur INSERT-Rechte, kein UPDATE/DELETE)

Jede manuelle Zeitkorrektur durch Admins wird revisionssicher protokolliert:

```json
{
  "admin_user_id": 1,
  "admin_name": "Administrator",
  "aktion": "zeitkorrektur",
  "tabelle": "zeiterfassung",
  "datensatz_id": 42,
  "mitarbeiter_name": "Fernando Marrero Lopez",
  "alter_wert": {"beginn": "08:00", "ende": "16:00"},
  "neuer_wert": {"beginn": "09:00", "ende": "17:00"},
  "begruendung": "Fehlerhafte Stempelung korrigiert",
  "erstellt_am": "2026-03-02T07:45:00+01:00"
}
```

Abgedeckte Aktionen:

- `zeitkorrektur` – Manuelle Änderung von Zeiteinträgen
- `zeitloeschung` – Löschen von Zeiteinträgen
- `lohnkorrektur` – Manuelle Lohnkorrektur
- `anonymisierung` – DSGVO-Anonymisierung nach Fristablauf
- `austritt_gesetzt` – Austrittsdatum gesetzt

---

2. Design & UI

2.1 Urlaubskalender – Individuelle Mitarbeiter-Farben

Sonderregel Fernando: `#8A2BE2` (Lila/Violett) – fest kodiert, unveränderlich.

Alle anderen Mitarbeiter erhalten automatisch eine eindeutige Farbe aus einer 12-Farben-Palette:

Farbe	Hex-Code
Blau	`#2196F3`
Grün	`#4CAF50`
Tief-Orange	`#FF5722`
Türkis	`#009688`
Pink	`#E91E63`
Orange	`#FF9800`
Braun	`#795548`
Blaugrau	`#607D8B`
Indigo	`#3F51B5`
Cyan	`#00BCD4`
Hellgrün	`#8BC34A`
Bernstein	`#FFC107`

Im Kalender wird eine **farbige Legende** oberhalb der Monatsansichten angezeigt. Bei mehreren Mitarbeitern am gleichen Tag wird die Farbe des ersten Mitarbeiters + eine Hochzahl (`+N`) angezeigt.

2.2 Dashboard-Konsolidierung

Die drei redundanten Admin-Tabs wurden zusammengeführt:

Vorher:

- Tab “Zeiterfassung”
- Tab “Zeitauswertung / Lohn”
- Tab “Lohnabrechnung”

Nachher:

- Tab **“Lohn & Zeiten”** mit Sub-Navigation (Selectbox):
  - 📊 Zeitauswertung & Zuschläge
  - 💰 Lohnabrechnung
  - ⏱️ Zeiterfassung (Live)
  - 📋 Audit-Log (Admin-Protokoll)

---

3. Automatisierung & E-Mail-Trigger

3.1 E-Mail-Trigger-Übersicht

Trigger	Empfänger	Funktion
Neuer Urlaubsantrag	Admin	`send_urlaubsantrag_email()` ✅
Urlaubsgenehmigung/-ablehnung	Mitarbeiter	`send_urlaubsgenehmigung_email()` ✅
Neuer Dienstplan veröffentlicht	Alle Mitarbeiter	`send_dienstplan_alle_mitarbeiter()` ✅
Stammdaten-Änderungsantrag	Admin	`send_aenderungsantrag_admin_email()` **NEU**
Neue Chat-Nachricht	Optional: alle	`send_chat_benachrichtigung_email()` **NEU**
DSGVO-Hygiene-Frist abgelaufen	Admin	`send_datenhygiene_warnung_email()` **NEU**
Lohnabrechnung erstellt	Mitarbeiter	`send_lohnabrechnung_email()` ✅

3.2 Daten-Hygiene / Cron-Job

Modul: `utils/datenhygiene.py`

Workflow:

1. Admin setzt Austrittsdatum → `loeschfrist_datum = ausgetreten_am + 10 Jahre` (§ 147 AO)
2. Monatliche Prüfung: `pruefe_faellige_loeschfristen()` findet abgelaufene Fristen
3. Admin erhält E-Mail-Warnung mit Liste der betroffenen Datensätze
4. Admin bestätigt Anonymisierung in der App
5. `anonymisiere_mitarbeiter()` ersetzt personenbezogene Daten

Anonymisierung (nicht Löschung):

Feld	Vorher	Nachher
Vorname	"Fernando"	"Ehemaliger"
Nachname	"Marrero Lopez"	"Mitarbeiter [42]"
E-Mail	"f.marrero@…"	NULL
Telefon	"+49 …"	NULL
Stundenlohn	14.50 €	0.00 €
Zeiterfassungs-Daten	Erhalten	Erhalten (kein Personenbezug)

> ***Rechtsgrundlage:*** *DSGVO Art. 17 (Recht auf Löschung) in Verbindung mit § 147 AO (10-jährige Aufbewahrungspflicht für Lohnunterlagen). Die Anonymisierung erfüllt beide Anforderungen.*

---

4. Kiosk-Modus (Stempeluhr)

4.1 PIN-Eingabe

- **Numpad entfernt** – reine Tastatureingabe
- Großes, sichtbares Eingabefeld mit Platzhalter "○ ○ ○ ○"
- **Enter-Taste** bestätigt die Eingabe (st.form)
- **×-Button** löscht die Eingabe (Reset funktioniert)

- Automatische Prüfung nach Bestätigung

4.2 KOMMEN/GEHEN-Buttons

- **KOMMEN:** Kräftiges Grün (`#1a7a3a`)
- **GEHEN:** Kräftiges Rot (`#c0392b`)
- CSS-Selektor mit hoher Spezifizität: `.st-key-btn_kommen div[data-testid="stButton"] > button`

---

5. Einmalige Admin-Aufgaben (Checkliste)

Folgende Schritte müssen einmalig manuell durchgeführt werden:

- [ ] **SQL-Migration ausführen:** `sql/DSGVO_SECURITY_SPRINT.sql` im Supabase SQL-Editor ausführen
- [ ] **Verschlüsselungs-Key setzen:** `DOKUMENT_VERSCHLUESSELUNGS_KEY` in Render.com Environment Variables
- [ ] **SMTP konfigurieren:** `SMTP_USERNAME` , `SMTP_PASSWORD` , `SMTP_SERVER` in Render.com
- [ ] **Spalten hinzufügen:** `ausgetreten_am` , `loeschfrist_datum` , `anonymisiert` in `mitarbeiter` -Tabelle (im SQL-Script enthalten)
- [ ] **Monatlicher Cron-Job:** In Render.com oder externem Dienst `fuehre_monatliche_hygiene_pruefung_durch()` monatlich aufrufen

---

6. Deployment

- **URL:** https://arbeitszeitverwaltung.onrender.com
- **Kiosk-URL:** `https://arbeitszeitverwaltung.onrender.com/?kiosk=1&geraet=DF336234`
- **GitHub:** TeamPicco/arbeitszeitverwaltung
- **Letzter Commit:** `48c5792` – feat: Finalisierungs-Sprint

Erstellt von CrewBase Entwicklungsteam – 02. März 2026